



大模型赋能漏洞自动化挖掘

林型双 王琴应 纪守领

Empowering automated vulnerability detection with LLMs

LIN Xingshuang, WANG Qinying, JI Shouling

在线阅读 View online: <http://js.xml-journal.net/article/doi/10.11991/cccf.202506004>

您可能感兴趣的其他文章

Articles you may be interested in

人工智能模型与开源：几点认识

Some thoughts on artificial intelligence models and open source

计算. 2025, 1(1): 14–19 <http://js.xml-journal.net/article/doi/10.11991/cccf.202505003>

智能时代的信息基础设施

Information infrastructure in the intelligent era

计算. 2025, 1(1): 20–23 <http://js.xml-journal.net/article/doi/10.11991/cccf.202505004>

打开网络流量背后的协议密码：基于大语言模型的网络流量生成之旅

Unlocking the protocol secrets behind network traffic: a journey into network traffic generation with large language models

计算. 2025, 1(1): 73–79 <http://js.xml-journal.net/article/doi/10.11991/cccf.202505012>

价值观罗盘评估中心：面向人机交互的大模型价值观评测平台

Value Compass Benchmarks: a comprehensive platform for evaluating large language models' values in human–AI interaction

计算. 2025, 1(1): 38–46 <http://js.xml-journal.net/article/doi/10.11991/cccf.202505008>

以人为中心的人智协同决策

Human–centered human–AI collaborative decision–making

计算. 2025, 1(1): 47–56 <http://js.xml-journal.net/article/doi/10.11991/cccf.202505009>

后摩尔时代集成电路发展的新机遇

New opportunities and ecosystem reconstruction for integrated circuits in the post–Moore era: insights from the 20th session of the CCF Beautiful Lake seminar

计算. 2025, 1(1): 88–95 <http://js.xml-journal.net/article/doi/10.11991/cccf.202505014>



关注微信公众号，获得更多资讯信息

大模型赋能漏洞自动化挖掘

林型双 王琴应 纪守领

浙江大学

引言

信息技术的飞速发展正在深刻变革各行各业,人类正迈入“软件定义”的时代。然而,层出不穷的软件漏洞已对国家安全、社会稳定和个人隐私构成了重大威胁,导致数据安全和网络安全问题日益复杂。根据天融信发布的《2023年网络空间安全漏洞态势分析研究报告》^[1],仅2023年,国家信息安全漏洞共享平台(China National Vulnerability Database, CNVD)披露的漏洞数量达到18635个,其中高危漏洞占比高达47.22%。这一高比例的高危漏洞突显了当前网络安全空间面临的严峻挑战。

自动化软件漏洞挖掘一直是信息安全领域的研究热点之一。根据技术原理,现有的漏洞自动化挖掘方法可分为静态分析、动态分析和形式化验证。

静态分析方法是在不执行待测程序的情况下,利用数据流分析、控制流分析和规则匹配等方法对程序源代码或字节码进行分析,进而识别潜在漏洞。代表性工具包括CodeQL^[2]和FlowDroid^[3]等。虽然静态分析技术在漏洞挖掘中取得了一定效果,但其并未真正运行程序,仅停留在代码静态审计层面,无法保证发现的潜在漏洞在实际运行中是否可被触发,导致误报率较高。

动态分析技术通过特定算法生成测试输入,模拟程序运行,并通过评估待测程序在特定测试输入下的运行时行为来识别潜在漏洞。代表性工具包括angr^[4]、AFL++^[5]和KLEE^[6]等。与静态分析相比,动态分析所

发现的漏洞在真实条件下具有可执行性,提高了检测结果的可信度。然而,动态分析方法通过反复生成输入并模拟程序运行,分析过程较为耗时,漏洞检测效率较低。此外,动态分析方法需要在程序执行前进行繁琐的环境配置,甚至同类型程序也可能需要不同的框架配置。因此,此类方法的适用范围较为有限。

形式化验证技术通过将待测程序的行为抽象为形式化模型,并定义程序应满足的安全性和正确性属性,利用严格的数学和逻辑方法来验证程序是否满足这些属性。如果待测程序不满足这些属性,则表示存在漏洞。代表性工具包括Z3^[7]和Tamarin^[8]等。形式化验证技术会对软件系统的全部可能行为进行理论验证,全面且高效地识别系统中的潜在漏洞。但由于涉及大量数学理论,这类方法的使用门槛和成本较高,特别是在大型软件系统上,实际应用难度较大。

2022年底,OpenAI发布了基于大模型的对话式聊天机器人程序——ChatGPT。其卓越的自然语言理解能力和复杂任务求解能力引发了全社会的广泛关注。大模型是指在海量无标注文本数据上进行预训练得到的大型预训练语言模型。在大模型诞生之初,信息安全领域的研究人员便设想将其运用于漏洞自动化挖掘,并在简单的软件系统上进行了初步探索。然而,面对复杂且真实的软件系统,如何充分利用大模型技术赋能漏洞自动化挖掘的发展,突破现有技术的瓶颈,已成为一个亟待解决的重要课题。基于此,本文梳理并总结了大模型技术在漏洞自动化挖掘领域的应用背景、发展方向、面临的挑战及潜在机遇,为相关研究人员提供参考和思路。

DOI: 10.11991/cccf.202506004

通信作者: 纪守领, E-mail: sji@zju.edu.cn

深度学习时代漏洞自动化挖掘的2类基本思想

大模型技术是深度学习技术进一步延伸发展的一个重要分支。在大模型技术出现之前,信息安全领域的研究人员已将深度学习技术应用于软件系统漏洞的自动化挖掘研究中。相关研究主要分为2类:第1类是在传统检测技术体系中嵌入深度学习模型,使其作为整体框架中的子模块来承担部分检测任务,构建性能更优的漏洞挖掘框架;第2类是以深度学习模型为核心的检测组件,构建专门用于漏洞自动化挖掘的技术框架。

在第1类方法的研究中,大多数传统技术框架均可以嵌入深度学习模型,在具体实现上,静态分析技术可以嵌入深度学习模型辅助数据流和控制流的分析,动态分析技术可以嵌入深度学习模型辅助模糊测试输入用例生成与编译,形式化验证技术可以嵌入深度学习模型辅助约束属性规则推理。例如,漏洞检测工具ILF构建了一个用于自动生成高价值序列的神经网络,从而提升模糊测试挖掘漏洞的效率^[9]。漏洞检测工具UVScan基于RoBERTa模型构建了阅读理解模型,对第三方组件误用检测时所需要的文档信息进行自动化处理,极大地减少了人工操作的工作量,提升了组件误用的检测效率^[10]。在第2类方法的研究中,所选用的深度学习模型类型多样,包括循环神经网络、图神经网络、卷积神经网络、全连接神经网络等。其中,基于循环神经网络的研究占比最多,其次是基于图神经网络的研究^[11]。这种选择主要源于各模型的特性对漏洞检测任务的不同适配性。循环神经网络能够结合程序代码的上下文信息,捕捉程序代码元素的依赖关系和顺

序特征,在漏洞检测中具有显著优势,如VulDeePecker^[12]。图神经网络则通过构建程序代码的图结构,分析代码中蕴含的图特征和元素之间的关系,从而实现漏洞的推理与判断,如AMPLE^[13]。

虽然这2类方法在一定程度上革新了漏洞自动化挖掘技术体系,并在一定程度上提升其能力,但是,这2类方法所依赖的深度学习模型多为参数规模小、训练数据有限、解决任务能力有限的传统小模型。这些模型的固有局限性对漏洞挖掘的整体效果构成了制约。例如,ILF中所生成的输入序列质量受到数据集规模和质量限制,进而影响后续漏洞挖掘的效果,VulDeePecker所识别的漏洞类型也局限于其所学习的历史漏洞数据。

目前,利用大模型解决漏洞自动化挖掘问题的相关研究,延续了深度学习技术的2类方法的基本思想,如图1所示。LLMIF^[14]、CellularLint^[15]、CarpetFuzz^[16]、ChatAFL^[17]、LLift^[18]、Fuzzing BusyBox^[19]、GPTScan^[20]、SMARTINV^[21]等是近期的代表性研究。例如,LLMIF是一种将大模型集成在物联网模糊测试中的技术框架。LLMIF首先将协议规范内容和格式注入大模型提示词(prompt)中,增强大模型对协议信息的提取能力;其次,利用模型提取的协议信息指导模糊测试用例的生成,进而提升物联网漏洞的挖掘能力。CellularLint是一种用于检测蜂窝网络协议与规范中不一致行为的技术框架。CellularLint采用了改进后的少样本学习机制,并在涵盖大量蜂窝网络协议的语料库对大模型进行预训练,构建了专用于自动化检测协议规范不一致性的大模型。总体而言,现有研究已在漏洞挖掘领域初步探索了大模型的应用场景并取得了一定成效。

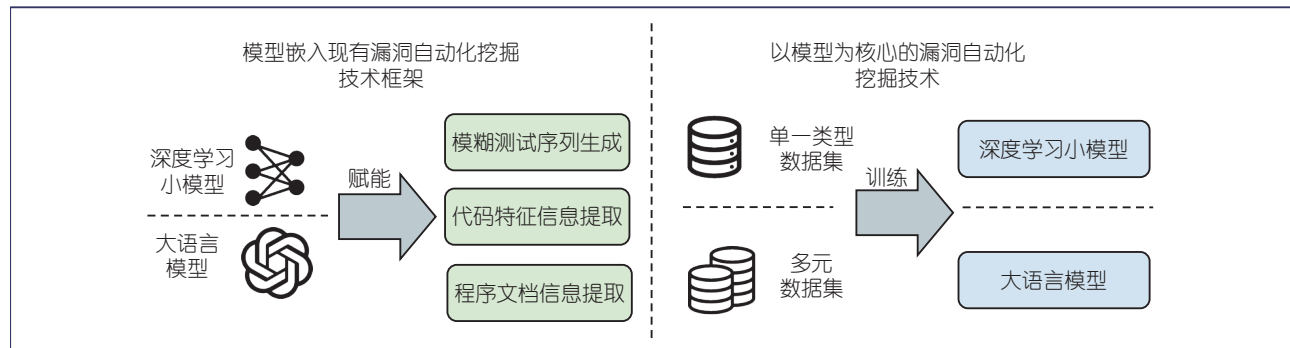


图1 深度学习技术赋能漏洞自动化挖掘2类基本思想对大模型技术的启示

大模型时代漏洞自动化挖掘的发展趋势

大模型通过扩大参数规模和数据规模,显著提升了自身能力,并在解决某些特定任务时实现了性能的飞跃。与小型深度学习模型对比,大模型展现出更强的通用任务处理能力和更好的复杂任务推理能力,从而在推动漏洞自动化挖掘任务中具有明显优势。同时,正因这些差异,当从传统小模型转向利用大模型构建技术体系时,不能简单地进行模型替换,而是要全面考虑大模型的独有特性及其涌现能力,有针对性地规划和构建基于大模型的漏洞自动化挖掘技术体系。那么,在利用大模型赋能漏洞自动化挖掘过程中,应从哪些方面入手才能更有效地激发其能力,从而充分发挥其独特优势。

提示工程

提示工程是在针对特定任务场景设计特定提示问题的过程,用以充分挖掘大模型在特定任务中的潜力。实现提示工程时通常采用上下文学习和思维链提示这2个策略。**上下文学习策略**是指在设计任务提示时候,在任务描述中加入与特定任务相关的参考信息作为大模型的输入,为大模型提供更多决策依据,帮助其更准确地解决任务。在漏洞挖掘中,可以为大模型提供包含待检测漏洞的示例代码、漏洞定义等上下文信息,使其更好地识别和定位潜在问题。**思维链提示策略**是指将复杂任务分解为若干个相对独立但又存在逻辑联系的子任务,逐步引导大模型完成推理与决策,增强大模型解决复杂任务的能力。在漏洞挖掘中,将拟检测漏洞的特征细化,且针对漏洞的细粒度特征设计多个子任务提示,引导模型对漏洞进行分步推理,从而更精准地识别漏洞。

指令微调

指令微调是指利用特定数据集对预训练后的大模型进行参数微调,以增强其在特定任务中的求解能力,并适配专业化领域的需求。在进行指令微调数据构建过程中,合理的指令格式设计和优化的指令表述可以显著提升大模型指令微调效果。例如,在**设计指令格式**时,可以在指令中插入一定数量的示例或者引入思

维链数据,以增强大模型的推理能力;在**优化指令表述**时,可以采用合成、重写和筛选等方式把低质量指令数据转换为高质量指令数据,提升模型的训练效果。在漏洞挖掘的任务中,可以针对目标漏洞类型构建一个专门的**指令微调数据集**,涵盖该目标类型**漏洞的特征、示例代码、修复措施**,同时还可以设计有助于漏洞推理的指令格式与指令表述,以提升大模型对该目标类型漏洞的检测能力。

检索增强生成

检索增强生成是指在利用大模型执行特定任务时,通过检索预构建领域知识库中的相关信息来辅助决策的技术。该方法通过引入领域知识库来解决模型在领域知识欠缺的情况下的能力局限,从而提升其问题求解能力。与指令微调不同,这类技术无须更新模型参数,因而在实现上更加简便高效。检索增强生成技术通常包括以下3个步骤:首先是**构建特定领域知识库**,该步骤需从该领域中的重要信息入手,收集高质量数据集,以增强大模型能力;其次是**检索知识库**,通过相似度计算、关键信息匹配或者规则匹配等方式动态检索知识库中收录的、与问询指令相关的信息;最后是**融合检索信息并生成响应**,将检索到的信息与当前输入的上下文信息相结合,共同作为大模型的输入,从而使大模型根据这些信息生成更加精确的响应。在漏洞挖掘场景中,检索增强生成可以通过构建包含漏洞定义、漏洞特征、利用方式、攻击案例等内容的知识库,为大模型提供参考。当大模型执行漏洞挖掘任务时,这些领域知识能够动态地提供支持,使其能够更高效地识别漏洞、推理漏洞机制并提出针对性解决方案。

工具学习

工具学习是指让大模型在学习使用外部工具来解决特定的任务,从而增强大模型的能力并丰富其功能。在许多实际场景中,大模型的能力往往受限于预训练数据集的覆盖范围或者用户提供知识的完整性,因此在实际运用中可能表现出一定的局限性。而工具学习通过引入外部工具可以拓展大模型的应用边界,使其能够适配更多任务需求,构建更复杂多样的自动化应用场景。

在漏洞挖掘场景中,工具学习同样具有重要的应用价值。具体而言,大模型在经过一定轮次的推理后,可根据漏洞特征以及现有检测工具的优势,自主调用现有的静态检测工具或动态检测工具,快速灵活地确认漏洞是否存在。例如,当大模型在经过多轮推理后,仍存在待定的静态特征,此时大模型可以调用集成的静态检测工具进行确认分析;当需要在程序运行场景中对代码特征进行动态验证时,大模型则可调用动态工具进行辅助判断。这种结合推理与工具的能力,能够有效弥补大模型在某些特定场景中的局限性,提升其在漏洞自动化挖掘中的效率和准确性,同时为构建高效的自动化漏洞检测体系提供了新的技术路径。

大模型智能体

大模型智能体是一个具备外部环境感知能力、规划能力和执行能力的复杂系统,在解决问题或完成任务时表现出高度的自动化能力。

一个成熟高效的大模型智能体一般会包含记忆、规划、执行和工具这4个基本组件。记忆组件负责存储大模型智能体与外部环境交互的历史记录,包括长期记忆和短期记忆。长期记忆保留需要持久化存储的

信息,如基本知识、历史经验等。而短期记忆保留模型上下文窗口中的临时信息,如当前外部环境的状态和近期的交互行为,短期记忆的存储时间比较短且容量有限,一般只在当前任务中使用。规划组件是智能体任务决策的核心,能够根据实际任务的复杂程度将其分解为多个子任务,并规划解决方案,包括但不限于思维链推理分析、工具调用等。规划组件还会参考记忆组件中所记录的信息动态优化和调整执行方案。执行组件是智能体解决任务的实际执行者,负责将规划组件制定的执行方案转换为智能体具体执行的动作行为,并在规划组件、记忆组织和工具组件的协同下与外部环境进行交互。工具组件集成了一系列智能体可以调用的工具,提升解决效率。

在漏洞自动化挖掘场景下,基于大模型的漏洞挖掘智能体能够增强传统漏洞挖掘系统的能力。现有的漏洞挖掘自动化工具往往是基于固定规则或海量数据,难以像人类专家一样进行全面、严格的推理分析。而漏洞挖掘智能体可以在一定程度上模仿人类专家的规划、思考、记忆和工具使用,精确识别代码中的漏洞,重塑漏洞挖掘的工作范式,进一步提升自动化能力。漏洞挖掘智能体的构造过程如图2所示。

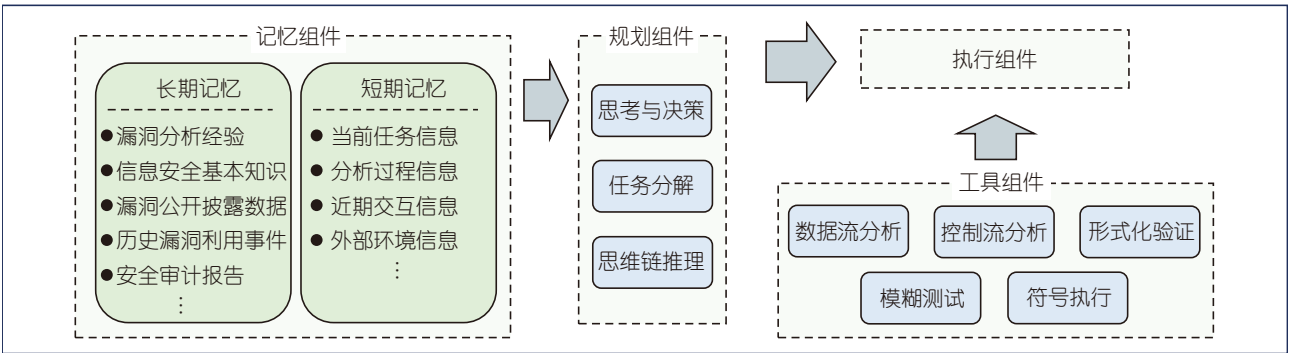


图2 漏洞自动化挖掘大模型智能体基本架构

首先,可以通过对漏洞挖掘智能体进行迭代的学习训练和高效的记忆储存及使用策略,为漏洞挖掘智能体注入高质量的漏洞挖掘经验;其次,可以参考人类专家在进行漏洞审计时的推理思维、漏洞挖掘方式,为漏洞挖掘智能体构造强大的规划组件,提升其任务规划能力。此外,漏洞挖掘智能体的工具组件可以集成静态分析、动态分析、形式化验证等多种自动化工具,为执行组件提供丰富的工具支撑。

除了构建单个漏洞挖掘智能体来解决漏洞挖掘任务,也可以构建漏洞挖掘智能体团队系统,通过从多角度协同分析程序漏洞。在漏洞挖掘智能体团队中,构建专注于不同任务的智能体角色,如规划任务与领导、程序分析、漏洞审计、漏洞利用等。这些智能体角色通过协同配合,共同提升智能体系统挖掘漏洞的能力,丰富其兼容的漏洞类型,从而进一步推动漏洞自动化挖掘技术的发展。

挑战与展望

挑战

大模型技术正在推动漏洞自动化挖掘技术的发展,但在这一过程中,仍然面临着以下挑战:

1)如何将大模型赋能漏洞自动化挖掘技术体系?

通过上文中对现有研究的论述分析可以发现,当前的大模型赋能漏洞自动化挖掘系统并没有从研究思想上进行革新,本质上还是延续深度学习时代的2类研究路径,只不过是使用性能优异的大模型来替代原先的小模型。如何从根本上让大模型赋能漏洞挖掘、发挥大模型的核心优势,是当下需要解决的重要问题。

2)如何利用大模型提升漏洞自动化挖掘的性能?

在漏洞自动化挖掘的研究中,准确率、误报率等定量的指标是用来衡量漏洞挖掘系统性能的重要依据。在大模型时代,我们是否可以从更多维度来提升漏洞自动化挖掘系统的能力?除此之外,我们是否还可以尝试用大模型去挖掘未知漏洞,打破对预定义漏洞类别规则的依赖。

3)在落地应用的过程中,需要注意哪些问题?

尽管在理论上使用大模型可以显著提升漏洞自动化挖掘系统的性能,但在落地过程中,我们要如何平衡大模型能力与系统开销,如何降低无关生成信息对系统的干扰等,这些都是需要解决的问题,否则,大模型赋能漏洞自动化挖掘的研究只会停留理论层面,难以产生实际价值。

展望

为了应对上述挑战,未来的研究可从以下3个方面进行探索:

1)创新大模型赋能漏洞自动化挖掘的研究思路

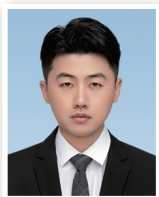
重视发挥大模型思维链推理能力,为漏洞自动化挖掘系统注入思考基因。以思考推理为核心,从根本上创新漏洞自动化挖掘系统的设计,构建具备“识别与规划任务、分析程序代码、参考已有知识、多轮推理与反复验证”的漏洞自动化挖掘智能体系统,突破深度学习时代用数据拟合生成来解决问题的思维局限性。

2)拓宽大模型对漏洞自动化挖掘的赋能路径

大模型应从多维度提升漏洞自动化挖掘系统的能力。从挖掘高质量漏洞的角度,需要研究大模型是否能够帮助发现更多高危漏洞,例如那些可能造成致命性攻击、严重经济损失或资源浪费以及影响范围广的高危漏洞。在扩展支持漏洞范围方面,需要探索大模型是否能够帮助检测传统工具难以发现的漏洞、与软件业务紧密相关的漏洞、难以抽象为规则的漏洞和现阶段只能依靠人类专家进行人工分析的漏洞。从挖掘未知漏洞的角度,需要构建一个能动态推理和总结未知类型漏洞特征的自动化挖掘未知漏洞的大模型框架。

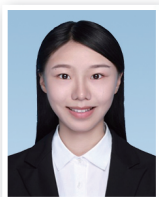
3)重视系统落地过程中遇到的实际问题

基于大模型的漏洞自动化挖掘系统的部署应用要坚持以需求为导向,一切从实际出发,既要提升系统效率,也要避免资源浪费。在平衡大模型能力与系统开销上,系统需要合理分配任务,让大模型去解决适合其发挥能力的任务,将较好解决的任务由传统技术或小模型承担。在降低无关生成信息对系统的干扰上,系统需要控制大模型生成信息的规模和质量,确保仅保留与任务高度相关的部分,避免对系统效率造成负面影响。



林型双

CCF 学生会会员。浙江大学计算机科学与技术学院博士研究生。主要研究方向为软件与系统安全、区块链安全。
cs.xslin@zju.edu.cn



王琴应

CCF 学生会会员。浙江大学计算机科学与技术学院博士研究生。主要研究方向为软件与系统安全、物联网安全。
wangqinying@zju.edu.cn



纪守领

CCF 高级会员。浙江大学计算机科学与技术学院教授/求是特聘教授、博士生导师。主要研究方向为人工智能安全、数据驱动安全、软件与系统安全、大数据挖掘与分析。
sji@zju.edu.cn

参考文献

- [1] 天融信阿尔法实验室. 2023 年网络空间安全漏洞态势分析研究报告 [EB/OL]. (2024-01-04)[2024-12-15]. <https://www.topsec.com.cn/newsx/4955>.
- [2] GitHub. CodeQL[EB/OL]. (2018-07-31)[2024-12-15]. <https://codeql.github.com/>.
- [3] ARZT S, RASTHOFER S, FRITZ C, et al. Flowdroid: precise context, flow, field, object-sensitive and lifecycle-aware taint analysis for android apps[J]. *ACM Sigplan Notices*, 2014, 49(6): 259–269.
- [4] SHOSHITAISHVILI Y, WANG Ruoyu, SALLS C, et al. SOK: (State of) the art of war: offensive techniques in Binary analysis[C]// *2016 IEEE Symposium on Security and Privacy*. Piscataway: IEEE, 2016: 138–157.
- [5] FIORALDI A, MAIER D, EIBFELDT H, et al. AFL++: combining incremental steps of fuzzing research[C]// *Proceedings of the 14th USENIX Workshop on Offensive Technologies*. Berkeley: USENIX Association, 2020: 1–10.
- [6] CADAR C, DUNBAR D, ENGLER D R. Klee: unassisted and automatic generation of high-coverage tests for complex systems programs[C]// *Proceedings of the 8th USENIX Conference on Operating Systems Design and Implementation*. Berkeley: USENIX Association, 2008: 209–224.
- [7] DE MOURA L, BJØRNER N. Z3: an efficient SMT solver[M]//BERTINO E, GAO WEN, STEFFEN B, et al. *Tools and Algorithms for the Construction and Analysis of Systems*. Heidelberg: Springer, 2008: 337–340.
- [8] BASIN D, CREMERS C, DREIER J, et al. Tamarin: verification of large-scale, real-world, cryptographic protocols[J]. *IEEE Security & Privacy*, 2022, 20(3): 24–32.
- [9] HE Jingxuan, BALUNOVIĆ M, AMBROLADZE N, et al. Learning to fuzz from symbolic execution with application to smart contracts[C]//ACM SIGSAC. *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*. London: ACM, 2019: 531–548.
- [10] ZHAO Binbin, JI Shouling, ZHANG Xuhong, et al. UVSCAN: detecting third-party component usage violations in IoT firmware[C]// *Proceedings of the 32nd USENIX Security Symposium*. Berkeley: USENIX Association, 2023: 3421–3438.
- [11] SHIRI HARZEVILI N, BOAYE BELLE A, WANG Junjie, et al. A systematic literature review on automated software vulnerability detection using machine learning[J]. *ACM Computing Surveys*, 2025, 57(3): 1–36.
- [12] LI Zhen, ZOU Deqing, XU Shouhuai, et al. VulDeePecker: a deep learning-based system for vulnerability detection[C]// *Network and Distributed System Security Symposium 2018*. San Diego: NDSS, 2018: 1–15.
- [13] WEN Xincheng, CHEN Yupan, GAO Cuiyun, et al. Vulnerability detection with graph simplification and enhanced graph representation learning[C]// *2023 IEEE/ACM 45th International Conference on Software Engineering*. Piscataway: IEEE, 2023: 2275–2286.
- [14] WANG Jincheng, YU Le, LUO Xiapu. LLMIF: augmented large language model for fuzzing IoT devices[C]// *2024 IEEE Symposium on Security and Privacy*. Piscataway: IEEE, 2024: 881–896.
- [15] RAHMAN M M, KARIM I, BERTINO E. CellularLint: a systematic approach to identify inconsistent behavior in cellular network specifications[C]// *Proceedings of the 33rd USENIX Conference on Security Symposium*. Berkeley: USENIX Association, 2024: 5215–5232.
- [16] WANG Dawei, LI Ying, ZHANG Zhiyu, et al. CarpetFuzz: automatic program option constraint extraction from documentation for fuzzing[C]// *Proceedings of the 32nd USENIX Conference on Security Symposium*. Berkeley: USENIX Association, 2023: 1919–1936.
- [17] MENG Ruijie, MIRCHEV M, BÖHME M, et al. Large language model guided protocol fuzzing[C]// *2024 Network and Distributed System Security Symposium*. San Diego: NDSS Symposium 2024 Program Committee, 2024: 1–17.
- [18] LI Haonan, HAO Yu, ZHAI Yizhuo, et al. Enhancing static analysis for practical bug detection: an LLM-integrated approach[J]. *Proceedings of the ACM on Programming Languages*, 2024, 8(OOPSLA1): 474–499.
- [19] ASMITA, OLIINYK Y, SCOTT M, et al. Fuzzing BusyBox: leveraging LLM and crash reuse for embedded bug unearthing[C]// *33rd USENIX Security Symposium*. Philadelphia: USENIX, 2024: 883–900.
- [20] SUN Yuqiang, WU Daoyuan, XUE Yue, et al. GPTScan: detecting logic vulnerabilities in smart contracts by combining GPT with program analysis[C]// *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*. New York: ACM, 2024: 1.
- [21] WANG S J, PEI Kexin, YANG Junfeng. SmartInv: multimodal learning for smart contract invariant inference[C]// *2024 IEEE Symposium on Security and Privacy*. Piscataway: IEEE, 2024: 2217–2235.

Empowering automated vulnerability detection with LLMs

LIN Xingshuang, WANG Qinying, JI Shouling

Zhejiang University

Abstract: The continuous emergence of software vulnerabilities presents significant threats across various industries, with their increasing complexity posing formidable challenges to the current cybersecurity landscape. As large language models (LLMs) continue to rise in prominence, the challenge of harnessing their capabilities to improve automated vulnerability detection and overcome existing technical limitations has become a critical issue. Firstly, this paper summarizes the key characteristics and limitations of traditional automated vulnerability detection tools. It then reviews research on the application of deep learning in vulnerability detection, emphasizing the theoretical and practical significance of utilizing LLMs for automated detection. Finally, the paper outlines potential research directions, challenges, and opportunities in the field of LLM-powered automated vulnerability detection.

Keywords: automated vulnerability detection; software and system security; large language model; vulnerability detection agent; artificial intelligence; information security

摘要: 层出不穷的软件漏洞已对各行各业构成了重大的威胁,并呈现出日益复杂的趋势,从而给当前的网络安全领域带来了严峻的挑战。随着大模型技术的兴起,研究如何利用这一技术促进漏洞自动化挖掘并突破现有技术的瓶颈,已成为信息安全领域的热点问题。针对这一背景,首先,归纳了现有漏洞自动化挖掘技术的主要特点及其局限性;其次,从深度学习技术赋能漏洞挖掘的技术思想出发,探讨了利用大模型开展漏洞自动化挖掘研究的理论和实践意义;最后,展望了大模型赋能漏洞自动化挖掘的潜在研究方向、面临的挑战和机遇。

关键词: 漏洞自动化挖掘; 软件与系统安全; 大模型; 漏洞挖掘智能体; 人工智能; 信息安全

中图分类号: TP309

中文引用格式: 林型双, 王琴应, 纪守领. 大模型赋能漏洞自动化挖掘 [J]. 计算, 2025, 1(2): 16–22.

英文引用格式: LIN Xingshuang, WANG Qinying, JI Shouling. Empowering automated vulnerability detection with LLMs[J]. *Computing Magazine of the CCF*, 2025, 1(2): 16–22.

2025 年度“CCF 青年科技奖”候选人提名启动

“CCF 青年科技奖”表彰在科学研究方面有突出成就和重要贡献的青年学者。该奖实行联名推荐制, 每年评选一次。

“青年科技奖 (CCF-IEEE CS Young Computer Scientist Award)”表彰年龄不超过 40 岁, 在科学研究、技术发明、系统开发及应用推广等方面有突出成就和重要贡献的青年学者, 每年获奖人数不超过 5 名; “青年科技奖 (CCF-ACM Award for AI)”表彰在人工智能理论、技术或应用方面作出杰出贡献, 且获奖时在中国工作的专业人士, 每年获奖人数 1 名, 如有合作的情形, 最多 3 人获奖。

候选人资格:

“青年科技奖 (CCF-IEEE CS Young Computer Scientist Award)”评选 1985 年 1 月 1 日以后出生的 CCF 会员; “青年科技奖 (CCF-ACM Award for AI)”可适当放宽年龄要求。

推荐要求:

由不少于 3 位 CCF 理事、监事或杰出会员及以上级别的会员联名推荐, 其中 1 位为主推荐人。每位推荐人每年推荐不得超过 2 人, 提名和附议的总数每年不得超过 3 人。推荐人中与被推荐人在同一单位的人数不得超过 1 人。

提名截止日期: 7 月 14 日。



扫码下载推荐表